Data Privacy and Security Note

Project Udyam Digital | Accel YTL Hackathon 2026, Enterprise Track A
Team BlackHack: Ayush Sahu, Chandrakant Gorain | NIT Jamshedpur

This prototype is **designed to align with** the Digital Personal Data Protection Act, 2023. It is not a legal compliance claim. All data used is synthetic, but we treat it as real personal data.

Principle	What we implemented
Notice and consent	Before KYC, the owner sees a versioned notice in English or Hindi: who holds the data, why, which fields, how long, their rights and a grievance contact. Boxes start unticked. Without consent, uploads and checks are refused. Each purpose is recorded with notice version, language and time.
Purpose limitation	Two required purposes: verify the business and install the service. WhatsApp updates are optional and recorded separately. The advisor greeting tells owners that staff may contact them and read the chat.
Data minimisation	Only the fields each document needs are kept. Photos exist only in a temporary file during reading and are deleted afterwards, even if reading fails. Blurry photos are refused before any AI call. The back-office never shows lead contact names.
Retention and withdrawal	The notice states 2,555 days, a prototype value that needs legal confirmation. Withdrawing consent deletes extracted fields and check results and releases any install slot. Consent records and order events stay as an audit trail. After installation, withdrawal goes to the Grievance Officer.
Masking and logging	GSTIN, Udyam and ID numbers are masked in API responses, screens and stored check evidence. The back-office also masks names read from documents and identifiers typed in chat. Logs hold IDs, stages, check codes and timings, not chat text or extracted values.
Secrets and service access	Keys stay in git-ignored files or environment variables. Only the AI service holds the Gemini key; the browser talks only to the backend. AI service endpoints need a shared token. The database connection requires TLS. Order lookup allows 10 attempts per IP in 10 minutes.
Staff access	The back-office needs a passcode and fails closed when none is set. This is a prototype gate: one shared passcode, with no individual logins.

What goes to the external AI, and why

Google Gemini receives chat text, the business profile and rules-engine results on each advisor turn, and readable document photos for field extraction. The advisor and document reading depend on this. Google's terms (effective 23 March 2026) allow unpaid-tier content to improve its products, allow human review, and say not to submit personal information. Our testing uses synthetic data only; **real customer data must not go through the unpaid tier**. On the paid tier, Google says prompts are not used to improve its products.

Known gaps in this prototype

The notice does not yet name Google Gemini. Chat has only a greeting line, not a consent step, and no retention limit. No job deletes data when retention ends. Extracted fields are stored unmasked because checks need them. The database is hosted outside India. Admin read endpoints and backend rules APIs are open, and order pages are protected only by their link. No screen lets owners view or correct their data. GST and Udyam lookups are mocks.

What production would add

A paid or enterprise AI tier under a data processing agreement; a notice naming every processor; consent before chat; automatic retention and deletion; individual staff logins with roles and audit logs; authentication on all APIs; field-level encryption; a reviewed hosting region; access and correction for owners; and legal review of the withdrawal and retention wording.